

HR & PAYROLL MANAGEMENT PLATFORM

Sprint 2 - Full-Stack Developer Handbook

Geofence Enforcement • Notifications • Expense Claims • Recruitment/ATS

Companion document

Read alongside *HR_Payroll_Sprint2_HLD.pdf* and the Sprint 1 v1.1 Handbook. This handbook only states rules that are new or changed in Sprint 2; Sprint 1 rules (AUTH-*, ORG-*, EMP-*, ATT-*, LEV-*, OT-*) remain in force unchanged unless noted.

Version 1.0 | September 2026 · Builds on Sprint 1 Handbook v1.1

How to Use This Handbook

This handbook stays beside the codebase throughout Sprint 2. It defines the four new module boundaries, business invariants, API behavior, security requirements, test cases, and implementation sequence. Where a rule is silent, the corresponding Sprint 1 rule still applies.

- Use Sections 1-5 during module design and infra setup.
- Use Sections 6-10 while implementing each new module.
- Use Sections 11-14 for API, database, storage, and security.
- Use Sections 15-18 for testing, backlog, Definition of Done, and roadmap.
- Record deliberate deviations from this handbook as Architecture Decision Records (ADRs), same discipline as Sprint 1.

Contents

1. Sprint 2 Vision and Baseline
 2. Sprint 2 Scope and Product Boundaries
 3. Actors, Roles and Permissions Update
 4. Core Architecture Additions
 5. Domain Model and Data Ownership Update
 6. Geofence Enforcement
 7. Notifications
 8. Expense Claims
 9. Recruitment / ATS
 10. Candidate-to-Employee Handoff
 11. REST API Contract and Validation
 12. Database Design and Integrity Rules
 13. File Storage and Uploads
 14. Security, Privacy and Operational Controls
 15. Testing Strategy and Critical Test Matrix
 16. Sprint Backlog and Implementation Order
 17. Definition of Done and Demo Script
 18. Post-Sprint-2 Extension Roadmap
- Appendix A. Suggested Entities and Fields
- Appendix B. Status Machines
- Appendix C. Example Calculations
- Appendix D. Developer Checklists

1. Sprint 2 Vision and Baseline

Sprint 1 delivered the employee-to-payslip MVP. Sprint 2 closes four gaps identified after launch: attendance needs a real access-control option for on-site staff, nobody is told when their request is decided, employees cannot claim expenses, and hiring happens outside the system. All four are additive to the Sprint 1 domain model.

Category	Sprint 2 Assumption
Baseline	Sprint 1 MVP v1.1 (GPS log-only attendance, org-scoped RBAC, modular monolith)
New modules	Geofence, Notifications, Expenses, Recruitment/ATS
New role	Hiring Manager (resource-scoped, not organization-wide)
New infrastructure	Redis (job queue), object storage (receipts/resumes)
Breaking change	One: <code>Organization.locationCaptureEnabled</code> (boolean) becomes <code>locationPolicy</code> (enum)

1.1 Sprint 2 Objectives

- Give organizations a real, opt-in access control on office attendance.
- Close the notification loop on every approval workflow already in the system.
- Let employees claim expenses through the same approval-then-payroll pattern as overtime.
- Run hiring inside the platform end-to-end, ending in a working employee account — without building a public careers site.

1.2 Success Metric for Sprint 2

Sprint 2 is successful when: an office employee outside a configured zone cannot check in and sees why; every leave/OT/payroll/expense decision produces a notification the recipient actually sees; an employee's approved expense appears correctly on their next payslip; and HR can take a candidate from job posting to a logged-in employee account without leaving the platform.

2. Sprint 2 Scope and Product Boundaries

Module	Sprint 2 Capability	Priority
Geofence	Org policy + zones; hard rejection for in-scope office check-ins	High
Notifications	Outbox, worker, in-app inbox, email, preferences	Critical
Expenses	Categories, claims, receipts, approval, payroll integration	Critical
Recruitment	Postings, candidates, pipeline, interviews, offers, conversion	High

2.1 Non-goals

- Public careers page or candidate self-service login.
- SMS/push notification channels.
- Calendar integrations for interviews.
- Standalone reimbursement outside the payroll cycle.
- Polygon geofence shapes (circular zones only).
- Performance/KPI, LMS, assets, bank disbursement, AI agent (unchanged from Sprint 1 §2.1).

2.2 Scope Control Rule

A feature belongs in Sprint 2 only if it is required to complete one of the four module workflows end-to-end, or to keep the platform secure/auditable — identical rule to Sprint 1 §2.2.

3. Actors, Roles and Permissions Update

Role	Responsibilities (new)	Sensitive Access
Super Admin	Unchanged, plus full access to all Sprint 2 modules	All new data
HR Admin	Manage geofence zones/policy, notification templates, expense categories/approval, full recruitment	Candidate compensation, offers, expense amounts
Hiring Manager new	Assigned candidates only: view profile, schedule/record interview feedback, advance stage up to but not including OFFER	None beyond assigned, non-compensation candidate data
Employee	Own notification inbox, own expense claims	Own records only

3.1 Permission Matrix (Sprint 2 additions)

Capability	Super Admin	HR Admin	Hiring Manager	Employee
Geofence policy/zones	R/W	R/W	-	-
Notifications	All	Manage templates + own inbox	Own inbox	Own inbox
Expense claims	All	Approve/reject + manage categories	Own claims only	Own claims: submit/view
Job postings	R/W	R/W	Read (assigned)	-
Candidates/pipeline	All	All	Assigned only, no compensation	-
Offers	R/W	R/W	-	-
Candidate conversion	Execute	Execute	-	-

3.2 Resource-Scope Invariant

Hiring Manager is Sprint 2's first role requiring resource-level authorization, not just type-level RBAC.

Every recruitment read/write for this role must check `application.hiringManagerId == currentUser.employeeId` in addition to the role check — never rely on role alone.

4. Core Architecture Additions

```
Web Client (React/TypeScript)
  | REST/JSON
API Layer -> Auth/RBAC -> Domain Services -> Repositories -> PostgreSQL
      |                                     |
      +--> notification_events (same txn) ---> Redis Queue -> Worker -> Email + in-app
rows
      |
      +--> Object Storage (receipts, resumes)
```

4.1 Recommended Stack Additions

Layer	Recommendation
Job queue	Redis + BullMQ (or equivalent)
Object storage	S3-compatible client, provider-agnostic adapter interface
Email	SMTP or transactional email provider behind a single adapter interface
Worker process	Separate Node.js entry point, same repo, same domain services

4.2 Layer Responsibilities (unchanged, extended)

- Controller: HTTP parsing, auth context, response mapping — unchanged.
- Service/domain: business rules, including geofence evaluation and offer/pipeline transitions.
- Repository: persistence only, including outbox and file-metadata rows.
- Worker: orchestrates dispatch only — must call the same notification-rendering logic the API would use, never duplicate it.

4.3 Money, Time and Files

- Expense amounts use the same DECIMAL/NUMERIC rule as payroll — never floating point.
- Geofence radius stored in meters as an integer or decimal; distance calculated server-side using the haversine formula (see Appendix C).
- Files are never stored as binary columns in PostgreSQL — object storage key + metadata only.

5. Domain Model and Data Ownership Update

```
Organization
|- GeofenceZone
|- NotificationTemplate
|- NotificationEvent (outbox)
|- ExpenseCategory
|- JobPosting -> Candidate -> CandidateApplication -> Interview
                                                    -> Offer -> (accept) -> Employee

Employee
|- ExpenseClaim -> ExpenseReceipt

User
|- Notification
|- NotificationPreference
```

5.1 Aggregate/Ownership Rules

- Organization owns GeofenceZone, NotificationTemplate, ExpenseCategory, JobPosting — same tenant-root pattern as Sprint 1 §5.1.
- Employee owns ExpenseClaim; ExpenseClaim owns its ExpenseReceipts.
- CandidateApplication is the pipeline aggregate; Interview and Offer belong to exactly one application.
- Notification belongs to exactly one User (recipient); NotificationEvent belongs to the Organization (may fan out to multiple recipients at dispatch time).
- Employee/User created by conversion are owned by the Employee module going forward — Recruitment retains only the traceability link (`convertedEmployeeId`).

6. Geofence Enforcement

Rule	Requirement
GEO-01	<code>Organization.locationPolicy</code> is one of NONE, LOG_ONLY, GEOFENCE_ENFORCED; default LOG_ONLY on migration from Sprint 1 v1.1 <code>locationCaptureEnabled=true</code> (false maps to NONE).
GEO-02	Enforcement (rejecting a check-in) only ever applies when policy = GEOFENCE_ENFORCED AND employee.work_model = OFFICE.
GEO-03	Hybrid/remote employees are exempt from rejection under every policy value, with no override.
GEO-04	Under GEOFENCE_ENFORCED for an in-scope employee, coordinates are mandatory; missing coordinates reject with <code>LOCATION_REQUIRED</code> (422).
GEO-05	Coordinates present but outside every active zone reject with <code>OUTSIDE_GEOFENCE</code> (422).
GEO-06	A check-in inside any one of the organization's active zones is accepted — zones are OR'd, not AND'd.
GEO-07	Only check-in is geofenced; check-out is never rejected for location.
GEO-08	A rejected check-in is not persisted as an AttendanceRecord; it is recorded to AuditLog only.
GEO-09	Zone create/update/delete and policy changes require HR Admin/Super Admin and are audited.

6.1 Distance Check

Use the haversine formula (Appendix C) to compute distance between the submitted coordinates and each zone center; the check-in is inside a zone if $\text{distance} \leq \text{zone.radius_meters}$. Do not approximate with simple Euclidean distance on raw lat/lng — the degree-to-distance ratio is not constant and will misjudge zones at typical office radii (50-300m).

6.2 Migration Note

Existing organizations with `locationCaptureEnabled=true` migrate to `locationPolicy=LOG_ONLY` (no enforcement, matches current behavior exactly); ones with `false` migrate to `NONE`. No organization is enforced by default — HR must explicitly opt in and define at least one zone before GEOFENCE_ENFORCED takes effect.

7. Notifications

Rule	Requirement
NOTIF-01	Every notification-worthy action writes a NotificationEvent row inside the same database transaction as the action itself.
NOTIF-02	A NotificationEvent insert failure rolls back the whole transaction (it is part of it); a downstream dispatch failure never does.
NOTIF-03	The worker is at-least-once: dispatch must be idempotent per event id so a re-processed event does not create a duplicate in-app Notification row.
NOTIF-04	Email bodies never include salary, expense amounts, or GPS coordinates — link back to the app instead.
NOTIF-05	Users may disable email per event type via NotificationPreference; in-app delivery cannot be disabled.
NOTIF-06	Failed events retry with backoff up to a configured max, then move to FAILED and stop retrying automatically.
NOTIF-07	If the worker/Redis is unavailable, events remain PENDING in PostgreSQL and are drained once the worker returns — no event is lost.

7.1 Event Catalog

- `leave.request.submitted` -> HR Admin(s)
- `leave.request.decided`, `overtime.request.decided` -> requesting employee
- `payroll.run.released` -> all employees in the run
- `expense.claim.decided` -> submitting employee
- `recruitment.interview.scheduled` -> assigned Hiring Manager(s)
- `recruitment.offer.responded` -> HR Admin who created the offer

7.2 Wiring Existing Sprint 1 Workflows

Adding notifications must not modify the business logic of leave/OT/payroll approval — only add one outbox insert at the point where the transaction already commits a state change. Treat this as a pure addition to each existing service method, not a rewrite.

8. Expense Claims

Rule	Requirement
EXP-01	A claim starts DRAFT and is editable only by its owning employee while DRAFT.
EXP-02	Submitting (DRAFT -> SUBMITTED) locks the claim from further employee edits.
EXP-03	If the category has <code>requiresReceipt=true</code> , submission without at least one receipt rejects with <code>RECEIPT_REQUIRED (422)</code> .
EXP-04	Only HR Admin/Super Admin may approve or reject a SUBMITTED claim.
EXP-05	Only APPROVED claims for the payroll period are payroll-eligible — same eligibility gate as OT-05.
EXP-06	A claim included in a calculated/approved PayrollRun cannot be edited or re-decided — same rule as OT-06.
EXP-07	Reimbursement amount is snapshotted into PayrollItem exactly like OT-07's payable-hours snapshot.
EXP-08	An employee may cancel their own DRAFT or SUBMITTED (pre-decision) claim; cannot cancel after APPROVED/REJECTED.

8.1 Suggested Categories

- Travel (receipt required)
- Meals (receipt required)
- Office Supplies (receipt required)
- Training/Certification (receipt required)
- Other (HR discretion on receipt requirement)

8.2 Concurrency Requirement

Approval and payroll inclusion must not race: a claim being approved at the exact moment a payroll run is calculating for that period must land deterministically on one side of the snapshot — same transactional discipline as leave-balance consumption (Sprint 1 §10.2).

9. Recruitment / ATS

Rule	Requirement
REC-01	Candidates are created by HR/Recruiter only; there is no public/unauthenticated intake endpoint in Sprint 2.
REC-02	Pipeline stage transitions are forward-only (APPLIED -> SCREENING -> INTERVIEW -> OFFER -> HIRED), except REJECTED/WITHDRAWN which are terminal from any stage.
REC-03	The same candidate email cannot have two open (non-terminal) applications to the same posting — reject with 409 <code>DUPLICATE_APPLICATION</code> .
REC-04	Only HR Admin/Super Admin may create, send, or rescind an Offer.
REC-05	An application may have at most one non-terminal (DRAFT/SENT) Offer at a time.
REC-06	Hiring Manager access is resource-scoped to <code>application.hiringManagerId</code> ; never expose compensation or offer terms to this role.
REC-07	Resume storage and access rules mirror expense receipts (§13) — signed URLs, HR Admin + assigned Hiring Manager only.
REC-08	A job posting cannot be deleted once it has candidates — deactivate (status=CLOSED/ARCHIVED) instead, same master-data pattern as MASTER-01.

9.1 Interview Rule

Interview scheduling is manual date/time entry only in Sprint 2 (no calendar integration). Feedback and score are free-text/numeric fields recorded by the assigned Hiring Manager or HR; there is no structured scorecard template requirement for Sprint 2.

10. Candidate-to-Employee Handoff

Rule	Requirement
HANDOFF-01	Conversion is only eligible when the application's Offer is ACCEPTED and the application has not already been converted.
HANDOFF-02	Conversion executes as a single database transaction creating exactly one User and one Employee, or none at all on failure.
HANDOFF-03	Conversion must call the existing Employee-creation service used by manual HR onboarding — never a duplicated code path.
HANDOFF-04	On success, CandidateApplication.stage becomes HIRED and <code>convertedEmployeeId</code> is set, permanently linking the two records.
HANDOFF-05	Conversion is audited with actor, candidateld, and the resulting employeeId.
HANDOFF-06	A second conversion attempt on an already-converted application rejects with 409 <code>CONVERSION_NOT_ELIGIBLE</code> .

Do not let Recruitment write directly to the `employees` or `users` tables from its own repository. Call into the Employee module's service layer so every Employee-creation invariant (EMP-01..EMP-06 from Sprint 1) is enforced identically regardless of entry point.

11. REST API Contract and Validation

Use the same versioned `/api/v1` REST convention and response envelope as Sprint 1 §17 (`{ success, data, meta }` / `{ success: false, error: { code, message } }`). No new envelope shape is introduced.

Domain	Representative Endpoint
Geofence	GET/PATCH <code>/api/v1/organization/geofence-policy</code> ; GET/POST/PATCH/DELETE <code>/api/v1/organization/geofence-zones[:id]</code>
Notifications	GET <code>/api/v1/notifications</code> ; PATCH <code>/api/v1/notifications/:id/read</code> ; GET/PATCH <code>/api/v1/notification-preferences</code>
Expenses	GET/POST <code>/api/v1/expenses/categories</code> ; GET/POST <code>/api/v1/expenses/claims</code> ; POST <code>/api/v1/expenses/claims/:id/receipts</code> ; POST <code>.../submit</code> ; POST <code>.../approve reject</code>
Recruitment	GET/POST <code>/api/v1/recruitment/postings</code> ; POST <code>.../candidates</code> ; PATCH <code>.../applications/:id/stage</code> ; POST <code>.../interviews</code> ; POST <code>.../offer</code> ; POST <code>.../offer/respond</code>
Handoff	POST <code>/api/v1/recruitment/applications/:id/convert</code>

Validation exists at the same four levels as Sprint 1 §19: frontend UX validation, API schema validation, domain/business validation, database constraints. Geofence coordinates are validated for numeric shape at the API layer; the distance-vs-zone decision is a domain/business-layer rule, never a schema validator.

12. Database Design and Integrity Rules

Rule	Requirement
DB2-01	Every new table carries <code>organization_id</code> (directly or via its parent) and is indexed on it, per Sprint 1 §8.
DB2-02	<code>notification_events</code> and <code>notifications</code> live in the same PostgreSQL database as every other table — no separate message store.
DB2-03	Unique constraint on (candidate email, job_posting_id) among non-terminal application stages, enforcing REC-03 at the database level in addition to the service check.
DB2-04	Unique constraint enforcing at most one non-terminal Offer per application (REC-05).
DB2-05	Foreign key from ExpenseClaim to PayrollItem is nullable and set only on reimbursement — never required at claim creation.
DB2-06	File-reference tables (ExpenseReceipt, Candidate.resume) store storage key + metadata only; no binary/blob columns.

13. File Storage and Uploads

Concern	Rule
Provider	S3-compatible object storage behind a single provider-agnostic adapter interface.
Allowed types	image/jpeg, image/png, application/pdf for both receipts and resumes.
Size limits	Receipts: 10 MB/file, max 5 files/claim. Resumes: 5 MB/file, one active per candidate.
Server-side enforcement	Size/mime checks happen on the API before the storage write — never trust the client to have enforced them.
Access	Signed, time-limited URLs generated per request; storage credentials never reach the browser.
Scanning	Shape-only validation (extension/mime/size) in Sprint 2; no malware/content scanning — document as an accepted limitation, not silently skipped.

14. Security, Privacy and Operational Controls

Risk	Control
Geofence bypass via missing coordinates	Coordinates mandatory for in-scope employees under GEOFENCE_ENFORCED (GEO-04)
Notification content leakage	No salary/expense amounts or GPS data in email bodies/subjects (NOTIF-04)
Receipt/resume exposure	Signed URLs, ownership/role-checked on every issuance
Candidate PII over-exposure	Hiring Manager scoped to assigned applications only, no compensation visibility (REC-06)
Duplicate/partial conversion	Single-transaction handoff (HANDOFF-02)
Upload abuse	Server-side size/mime enforcement (§13)

Audit at minimum, in addition to Sprint 1 §18: geofence zone/policy changes; rejected geofenced check-ins; expense approval/rejection; job posting create/close; offer creation/rescission/response; candidate-to-employee conversion.

15. Testing Strategy and Critical Test Matrix

Test Layer	Examples
Unit	Haversine distance calc, expense reimbursement snapshot, offer/pipeline state transitions
Service	Reject geofenced check-in, approve expense, convert candidate to employee
Repository	Org scoping on new tables; duplicate-application and single-active-offer constraints
API integration	Hiring Manager resource-scope enforcement, receipt/resume upload validation, notification preference toggles
E2E	Posting -> candidate -> interview -> offer -> accept -> convert -> new employee logs in
Worker	Exactly-once effective delivery under at-least-once processing; retry/backoff; restart safety

Critical invariants

- A GEOFENCE_ENFORCED office employee cannot check in from outside every configured zone.
- A hybrid/remote employee is never rejected for location, under any policy.
- An expense claim is reimbursed at most once and only after HR approval.
- An application converts to an employee at most once.
- A Hiring Manager cannot read another Hiring Manager's assigned candidates, or any compensation/offer data.
- A failed or delayed notification dispatch never rolls back its triggering business transaction.

16. Sprint Backlog and Implementation Order

Order	Work Package	Deliverable
1	Infra foundation	Redis, object storage adapter, new migrations
2	Geofence	Zones + policy schema, enforcement logic, org settings UI
3	Notifications core	Outbox, templates, worker, in-app inbox API
4	Notification wiring	Emit events from leave/OT/payroll; bell + preferences UI
5	Expenses	Categories, claims, receipts, HR approval, frontend
6	Expenses-payroll link	Approved claims as payroll input, snapshot in PayrollItem
7	Recruitment core	Postings, candidates, pipeline, interviews
8	Offers & handoff	Offer lifecycle, candidate-to-employee conversion, notification wiring
9	Hardening	Audit coverage, Hiring Manager RBAC tests, security review
10	Release	Staging with real queue/storage, migration, demo script

17. Definition of Done and Demo Script

- All Sprint 2 modules have authenticated and authorized APIs.
- Migrations apply cleanly on Sprint 1 v1.1 schema, including the locationPolicy migration.
- Geofence enforcement is verified for office employees and verified absent for hybrid/remote.
- Notification delivery is verified end-to-end (in-app + email) for every catalog event.
- Approved expense claims are verified to appear once, correctly, on the next payslip.
- Full recruitment pipeline produces a working employee login via conversion.
- Hiring Manager scope restrictions are verified by automated test, not just manual QA.
- CI passes lint, tests, and build for both API and worker images.

Demo Script

1. HR enables GEOFENCE_ENFORCED and defines one zone; an office employee checks in from outside it and is rejected, then checks in from inside it and succeeds.
2. HR approves a leave request; the employee sees an in-app notification and receives an email without any leave-day counts in it.
3. Employee submits an expense claim with a receipt; HR approves it; the next payroll run shows it reimbursed on the payslip.
4. HR posts a job, enters a candidate, schedules an interview (Hiring Manager records feedback), sends an offer, records acceptance, and converts the candidate — the new employee logs in.

18. Post-Sprint-2 Extension Roadmap

Future	Integration Point
Public careers page / candidate portal	Recruitment module, new unauthenticated intake endpoint
Polygon geofence zones	Geofence module, additive zone-shape field
SMS/push notifications	Notification dispatcher, new channel adapter
Calendar integration	Interview scheduling, external adapter
Standalone reimbursement	Expenses module, decoupled from payroll cycle
Performance/KPI, LMS, Assets, Bank disbursement, AI agent	As per Sprint 1 HLD Appendix D

Appendix A. Suggested Entities and Fields

Entity	Key Fields / Notes
Organization (extended)	location_policy (NONE LOG_ONLY GEOFENCE_ENFORCED)
GeofenceZone	id, organization_id, label, lat, lng, radius_meters, status
NotificationTemplate	id, organization_id, event_type, channel, subject, body_template
NotificationEvent	id, organization_id, event_type, payload, status, attempts, created_at
Notification	id, organization_id, user_id, title, message, related_resource_type/id, read_at
NotificationPreference	id, user_id, event_type, email_enabled
ExpenseCategory	id, organization_id, name, requires_receipt, status
ExpenseClaim	id, organization_id, employee_id, category_id, amount, expense_date, description, status, payroll_item_id
ExpenseReceipt	id, expense_claim_id, storage_key, file_name, mime_type, size_bytes
JobPosting	id, organization_id, title, department_id, position_id, employment_type, openings, status
Candidate	id, organization_id, full_name, email, phone, resume_storage_key, source, converted_employee_id
CandidateApplication	id, candidate_id, job_posting_id, stage, hiring_manager_id
Interview	id, application_id, scheduled_at, mode, interviewer_ids, feedback, score, status
Offer	id, application_id, proposed_salary, currency, start_date, status, sent_at, responded_at

Appendix B. Status Machines

Expense Claim

```
DRAFT -> SUBMITTED -> APPROVED -> REIMBURSED
      |
      --> REJECTED
DRAFT/SUBMITTED --> CANCELLED
```

Candidate Application

```
APPLIED -> SCREENING -> INTERVIEW -> OFFER -> HIRED
|           |           |           |
+-----+-----+-----+-----> REJECTED / WITHDRAWN
```

Offer

```
DRAFT -> SENT -> ACCEPTED -> (convert) -> HIRED
      |
      --> DECLINED
DRAFT/SENT --> RESCINDED
```

Notification Event

```
PENDING -> PROCESSED
      |
      --> FAILED (after max retries)
```

Appendix C. Example Calculations

Geofence distance (haversine)

```
a = sin2(Δlat/2) + cos(lat1) · cos(lat2) · sin2(Δlng/2)
c = 2 · atan2(√a, √(1-a))
distanceMeters = EARTH_RADIUS_M (6371000) × c

inside_zone = distanceMeters <= zone.radiusMeters
```

Notification retry backoff

```
delay(attempt) = min(baseDelayMs * 2(attempt-1), maxDelayMs)
e.g. baseDelayMs=5000, maxDelayMs=300000, maxAttempts=5
attempt 1: 5s, 2: 10s, 3: 20s, 4: 40s, 5: 80s -> then FAILED
```

Expense reimbursement in payroll

```
Gross = Basic Salary + Fixed Allowances + Approved Overtime + Bonus + Approved Expense
Reimbursements
Net = Gross - Fixed Deductions - Unpaid Leave Deduction - Other Authorized Deductions
```

Appendix D. Developer Checklists

Before opening a Sprint 2 PR

- New table has `organization_id` (direct or via parent) and is indexed on it.
- New endpoint follows the existing envelope and error-code conventions (§11).
- Any state transition is guarded by a check on current state, not assumed from the request.
- Any notification-worthy action writes its outbox event in the same transaction as the state change.
- Any file upload enforces size/mime server-side, not just in the frontend.
- Any new role-based check is paired with a resource-scope check where applicable (Hiring Manager).
- Sensitive action is audited.
- Tests cover the critical invariant list in §15, not just the happy path.